

Insecure Direct Object Reference & HTTP Security Headers





موضوع :

Insecure Direct Object Reference & HTTP Security Headers



تهیه شده توسط تیم TryHackBox

The Chaos



لینک زیر جهت حمایت از جامعه آموزش رایگان :

<https://daramet.com/TryHackBox>

ما را به دوستانتان معرفی کنید .

دیگر کانال ها و شبکه های اجتماعی ما را دنبال کنید:

کانال های تلگرام ما

آموزش تست نفوذ و Red Team :

[@TryHackBox](https://t.me/TryHackBox)

رودمپ های مختلف:

[@TryHackBoxOfficial](https://t.me/TryHackBoxOfficial)

داستان های هک:

[@TryHackBoxStory](https://t.me/TryHackBoxStory)

آموزش برنامه نویسی:

[@TryCodeBox](https://t.me/TryCodeBox)

رادیو زیروپاد (پادکست ها):

[@RadioZeroPod](https://t.me/RadioZeroPod)

اینستاگرام :

<http://www.instagram.com/TryHackBox>

یوتیوب:

<https://youtube.com/@tryhackbox>





Insecure Direct Object Reference (IDOR)

• IDOR مخفف "Insecure Direct Object Reference" به معنای "ارجاع مستقیم ناامن به شیء" است.

- این یک آسیب‌پذیری امنیتی است که زمانی رخ می‌دهد که یک برنامه به کاربران اجازه می‌دهد تا بر اساس ورودی ارائه‌شده توسط کاربر (مانند پارامترهای ورودی یا کوکی‌ها) مستقیماً به اشیاء (مانند فایل‌ها، رکوردهای پایگاه داده یا URL‌ها) دسترسی داشته باشند.
- مهاجمان می‌توانند این ارجاع‌ها را دستکاری کنند تا به داده‌های غیرمجاز دسترسی پیدا کنند یا اقداماتی را انجام دهند که مجاز به انجام آن نیستند.

تأثیر IDOR

- تأثیر IDOR می‌تواند شدید باشد و شامل موارد زیر است:
- دسترسی غیرمجاز به داده‌های حساس.
 - دستکاری داده‌ها، جایی که مهاجمان می‌توانند داده‌ها را تغییر دهند.
 - افزایش سطح دسترسی (اسکالیشن امتیازات)، که به کاربران اجازه می‌دهد به دسترسی سطح بالاتر دست یابند.
 - افشای اطلاعات شخصی، داده‌های مالی یا سوابق محرمانه.
 - پتانسیل از دست دادن یا تخریب داده‌ها.



هدرهای امنیتی HTTP

- هدرهای امنیتی HTTP، هدرهای پاسخی هستند که توسط یک سرور وب ارسال می‌شوند تا به مرورگرها دستور دهند که هنگام تعامل با یک صفحه وب چگونه رفتار کنند.
- آن‌ها با کاهش انواع تهدیدات، به افزایش امنیت برنامه‌های وب کمک می‌کنند.

انواع مختلف هدرهای امنیتی

- خط‌مشی امنیت محتوا (Content-Security-Policy یا CSP):
 - منابع مجاز محتوا را مشخص می‌کند و از حملات تزریق اسکریپت XSS و تزریق داده جلوگیری می‌نماید.
- گزینه‌های نوع محتوا (X-Content-Type-Options):
 - با جلوگیری از عمل "sniffing" (حدس زدن) نوع MIME توسط مرورگرها، یکپارچگی داده‌ها را افزایش می‌دهد.
- گزینه‌های قاب (X-Frame-Options):
 - قرارگیری صفحه در یک قاب (iframe) را کنترل می‌کند تا از حملات کلیک‌دزدی (clickjacking) جلوگیری کند.
- حفاظت در برابر XSS (X-XSS-Protection):
 - فیلترهای محافظ در برابر XSS را در مرورگرها فعال می‌کند.



- امنیت حمل و نقل سخت گیرانه (Strict-Transport-Security یا HSTS):

- استفاده از پروتکل HTTPS را اجباری می کند تا حملات مرد میانی (MITM) را خنثی نماید.

- خط مشی ارجاع دهنده (Referrer-Policy):

- هدر Referrer در HTTP را کنترل می کند تا حریم خصوصی را افزایش دهد.

- خط مشی ویژگی ها (Feature-Policy):

- مشخص می کند که کدام ویژگی های وب مجاز هستند.

- انتظار برای شفافیت گواهی (Expect-CT):

- شفافیت گواهینامه (Certificate Transparency) را برای گواهی های SSL/TLS اجرا می کند.

- خط مشی منابع مبدأ متقاطع (Cross-Origin-Resource-Policy):

- نحوه برخورد با درخواست های مبدأ متقاطع (cross-origin) را کنترل می کند.

- پین کردن کلید عمومی (Public-Key-Pins یا HPKP) (منسوخ شده):

- کلیدهای عمومی معتبر برای گواهی های SSL/TLS را مشخص می کرد (امروزه دیگر توصیه نمی شود).



ارتباط این هدرها با سناریوهای IDOR

هدرهای امنیتی به طور مستقیم از آسیب پذیری IDOR جلوگیری نمی کنند. IDOR یک مشکل لاگیک برنامه (Logic Flaw) است که در لایه منطق کسب و کار و Authorization (احراز صلاحیت) برنامه رخ می دهد. برای رفع آن، باید در کد backend بررسی کنید که آیا کاربر مجاز به دسترسی به آن شی (object) خاص است یا خیر.

اما، این هدرها چگونه به طور غیرمستقیم در سناریوهای امنیتی مرتبط کمک می کنند؟

1. کنترل آسیب پذیری های مرتبط: بسیاری از حملات ترکیبی هستند. یک مهاجم ممکن است از یک آسیب پذیری دیگر (مثل XSS) برای استخراج توکن های جلسه (session tokens) استفاده کند و سپس از آن توکن برای انجام یک حمله IDOR با هویت قربانی سوءاستفاده کند.

- CSP و X-XSS-Protection با کاهش خطر موفقیت آمیز حملات XSS، این مسیر حمله را مسدود یا سخت تر می کنند.

TryHackBox

2. حفاظت از اطلاعات حساس در حین انتقال: هنگامی که یک حمله IDOR موفقیت آمیز باشد، مهاجم داده های حساس را می دزدد.

- HSTS تضمین می کند که این داده های دزدیده شده همیشه از طریق یک راهرو رمز گذاری شده (HTTPS) انتقال می یابند و از استراق سمع (eavesdropping) توسط مهاجمان دیگر در شبکه جلوگیری می کند.



3. محدود کردن نحوه نمایش داده‌ها: اگر یک صفحه حاوی اطلاعات حساس (که از طریق IDOR پیدا شده) بتواند در یک `iframe` قرار گیرد، ممکن است برای یک حمله کلیک‌دزدی استفاده شود.

- **X-Frame-Options** با جلوگیری از نمایش صفحه در یک فریم، از این امر جلوگیری می‌کند.

4. محروم کردن مهاجم از اطلاعات: هنگامی که یک کاربر از یک برنامه به برنامه دیگر می‌رود، هدر **Referer** اغلب حاوی اطلاعات حساسی مانند توکن‌ها، شناسه‌ها یا مسیرهای URL است.

- **Referrer-Policy** با کنترل میزان اطلاعاتی که در هدر **Referer** ارسال می‌شود، از نشت ناخواسته اطلاعاتی که ممکن است به یک مهاجم در شناسایی پارامترهای قابل دستکاری برای یک حمله IDOR کمک کند، جلوگیری می‌نماید.

TryHackBox

جمع‌بندی: هدرهای امنیتی یک لایه دفاعی ضروری هستند که با کاهش سایر بردارهای حمله و محدود کردن عواقب نشت داده‌ها (از جمله نشت ناشی از IDOR)، امنیت کلی برنامه را تقویت می‌کنند. آنها مکمل بسیار خوبی برای رفع آسیب‌پذیری IDOR در سمت سرور هستند، اما جایگزین بررسی مجوزهای صحیح (Authorization checks) نمی‌شوند.